Week-4

1# Illustrate major potential security vulnerabilities in web applications. Use a checklist to document the vulnerabilities and suggest basic countermeasures.

The following checklist is aligned with common risks identified by OWASP **(Open Web Application Security Project).** OWASP is a global non-profit organization focused on improving software security.

Web Application Security Vulnerability Checklist Are as follows:

Vulnerabilities	Impact	Countermeasures
☐ **SQL Injection (SQLi)** **Description:** Malicious SQL statements inserted into input fields to manipulate databases.	Data theft, unauthorized access, data modification.	• Use parameterized queries (prepared statements) • Input validation and sanitization • Use ORM frameworks • Apply least-privilege database access
☐ **Cross-Site Scripting (XSS)** **Description:** Injection of malicious scripts into web pages viewed by users.	Session hijacking, credential theft, website defacement.	• Output encoding • Input validation • Implement Content Security Policy (CSP) • Sanitize user-generated content
☐ **Cross-Site Request Forgery (CSRF)** **Description:** Unauthorized actions performed on behalf of authenticated users.	Unauthorized transactions or account changes.	• Use CSRF tokens • Enable SameSite cookies • Re-authenticate for sensitive actions
☐ **Broken Authentication** **Description:** Weak login mechanisms or improper session handling.	Account takeover.	• Enforce strong password policies • Multi-Factor Authentication (MFA) • Secure session management • Account lockout after failed attempts
☐ **Broken Access Control** **Description:** Improper enforcement of user permissions	Privilege escalation, unauthorized data access.	• Role-Based Access Control (RBAC) • Server-side validation • Deny-by-default access rules
☐ **Security Misconfiguration** **Description:** Default settings, open ports, unnecessary services enabled.	System compromise.	• Disable unused features • Regular configuration audits • Keep software updated • Harden servers
☐ **Sensitive Data Exposure** **Description:** Failure to protect confidential data	Data breach, legal penalties.	• Use HTTPS (TLS encryption)

		• Encrypt sensitive data at rest • Secure key management • Avoid storing unnecessary sensitive data
☐ **Insecure File Uploads** **Description:** Uploading malicious files disguised as safe content.	Remote code execution, malware infection.	• Validate file types and size • Store files outside web root • Scan uploads with antivirus tools
☐ **Unvalidated Redirects and Forwards** **Description:** Redirecting users to malicious websites.	Phishing attacks.	• Use whitelist of trusted URLs • Avoid dynamic redirects based on user input
☐ **Insufficient Logging and Monitoring** **Description:** Lack of detection of suspicious activities.	Delayed breach detection and response	• Enable activity logging • Use intrusion detection/prevention systems • Monitor logs regularly • Implement incident response plan

Web application vulnerabilities can lead to serious consequences such as data breaches, financial loss, and reputational damage. Using this checklist approach helps organizations systematically identify weaknesses and apply preventive controls.

2# Categorize the following hypothetical scenarios into different types of cybercrimes (e.g., hacking, identity theft, online fraud) and suggest how they can be prevented.

a. Hacking

Category: Unauthorized Access / Cyber Intrusion
Description: Gaining illegal access to computer systems, networks, or accounts.
Examples: Breaking into company servers, defacing websites.
Prevention:

- Strong passwords & Multi-Factor Authentication (MFA)
- Firewalls and intrusion detection systems
- Regular security updates and patching
- Penetration testing

b. Identity Theft

Category: Personal Data Crime
Description: Stealing someone's personal information to impersonate them.
Examples: Using stolen credit card details or Aadhaar number.
Prevention:

- Encrypt sensitive data
- Avoid sharing personal information publicly
- Monitor bank and credit reports

- Enable MFA

c. Online Fraud

Category: Financial Cybercrime
Description: Deceptive online schemes for financial gain.
Examples: Phishing emails, fake shopping websites.
Prevention:

- Verify website authenticity (HTTPS)
- Avoid suspicious links
- Use secure payment gateways
- Awareness training

d. Cyberstalking and Harassment

Category: Online Abuse
Description: Repeated threatening or abusive behavior online.
Examples: Sending threatening messages on social media.
Prevention:

- Use privacy settings
- Block/report offenders
- Preserve evidence
- Legal action under cyber laws

e. Malware Attack

Category: Malicious Software Crime
Description: Use of viruses, ransomware, spyware, or trojans to damage systems.
Examples: Ransomware encrypting files.
Prevention:

- Install antivirus software
- Avoid downloading unknown attachments
- Regular system updates
- Data backups

f. DDoS

Category: Network Attack
Description: Flooding a server with traffic to make it unavailable.
Examples: Botnet attack on a website.
Prevention:

- DDoS mitigation services
- Load balancing
- Rate limiting
- Web Application Firewall (WAF)

g. Eavesdropping

Category: Communication Interception
Description: Unauthorized interception of private communications.

Examples: Packet sniffing on public Wi-Fi.
Prevention:

- Use VPN
- Enable HTTPS encryption
- Secure Wi-Fi with strong passwords
- Avoid public networks for sensitive tasks

h.Cyber Espionage

Category: National/Corporate Security Crime
Description: Spying to steal confidential government or corporate data.
Examples: State-sponsored hacking of defense systems.
Prevention:

- Network segmentation
- Strong encryption
- Advanced threat detection systems
- Employee background verification

i.Intellectual Property Theft

Category: Digital Piracy / Data Theft
Description: Stealing copyrighted material, trade secrets, or software code.
Examples: Copying proprietary software.
Prevention:

- Access control systems
- Digital Rights Management (DRM)
- Legal agreements (NDAs)
- Monitoring and logging

j. Online Defamation

Category: Reputation-Based Cybercrime
Description: Publishing false information to harm someone's reputation.
Examples: False allegations on blogs or social media.
Prevention:

- Monitor online presence
- Report harmful content
- Take legal action if required
- Promote digital responsibility

k. Child Exploitation

Category: Severe Cybercrime / Abuse
Description: Online abuse, grooming, or sharing illegal content involving minors.
Prevention:

- Parental control software
- Monitor children's online activity
- Awareness programs
- Report to cybercrime authorities

l. Cyberbullying

Category: Online Harassment
Description: Repeated intimidation, humiliation, or threats online.
Examples: Posting embarrassing content to harm someone.
Prevention:

- Use privacy controls
- Block/report offenders
- School/organizational anti-bullying policies
- Counseling and awareness programs

3# Create a timeline of key events in the development of the Indian IT Act. Discuss any one section of the act (e.g., Section 46, 66, 66A) with its implications in combating cybercrime.

Information Technology Act, 2000. The IT Act was enacted to provide legal recognition to electronic records and digital transactions and to address cybercrime in India.

Key Events

YEAR	Event
1998	Drafting of cyber law initiated by the Ministry of Information Technology
2000	IT Act, 2000 passed by the Indian Parliament (came into force on 17 October 2000)
2008	IT (Amendment) Act, 2008 passed to address emerging cyber threats
2009	Amended provisions came into force (stronger penalties, new cyber offences added)
2015	Section 66A struck down by the Supreme Court of India in Shreya Singhal v. Union of India
Present	Ongoing updates aligned with data protection and cybersecurity frameworks

SECTION 66

Section 66 deals with **computer-related offences**, particularly acts involving dishonest or fraudulent activities using computers.It applies when a person:

- Accesses a computer system without authorization (hacking)
- Downloads, copies, or extracts data illegally
- Introduces viruses or malware
- Causes damage or disruption to systems
- Denies access to authorized users (e.g., DoS attacks)

PUNISHMENTS

- Imprisonment up to **3 years**, or
- Fine up to **₹5 lakh**, or
- Both

IMPLICATIONS

1)**Legal Recognition of Hacking** Section 66 clearly defines hacking and related activities as criminal offences.

2)**Deterrent Effect** Provides strict penalties that discourage cybercriminal activities.

3)**Protection of Digital Infrastructure** Safeguards banks, e-commerce platforms, government portals, and private systems.

4)**Supports Cybercrime Prosecution** Enables law enforcement agencies to register cases and prosecute offenders.

5)**Enhances Digital Trust** Encourages secure online transactions and growth of the digital economy.

4# Draft a basic security policy for a small office setup, focusing on password policies, data backup policies, and internet usage guidelines.

Basic Security Policy for a Small Office Setup

Organization Name: _____
Effective Date: _____
Approved By: _____

Purpose

This policy establishes basic security guidelines to protect the organization's information systems, data, and network infrastructure from unauthorized access, misuse, or damage.

Scope

This policy applies to:

- All employees, contractors, and interns
- All office computers, laptops, mobile devices
- Company email systems and internet access
- Cloud storage and backup systems

Password Policy

Password Requirements

- Minimum **12 characters** in length
- Must include:
  - At least one uppercase letter (A–Z)
  - At least one lowercase letter (a–z)
  - At least one number (0–9)
  - At least one special character (!@#$%^&*)
- Must not contain:
  - User's name or username
  - Common passwords (e.g., "password123")

Password Management

- Passwords must be changed every **90 days**
- Password reuse is prohibited (last 3 passwords cannot be reused)
- Passwords must not be shared
- Multi-Factor Authentication (MFA) must be enabled where available
- Accounts will be locked after **5 failed login attempts**

Administrative Controls

- Default system passwords must be changed immediately
- Privileged accounts must use stronger controls
- Password managers may be used with approval

Data Backup Policy

Backup Frequency

- **Daily incremental backups** of active data
- **Weekly full backups** of all systems

Backup Storage

- One backup copy stored onsite
- One backup copy stored offsite or in secure cloud storage
- Backup data must be encrypted

Backup Testing

- Backup restoration must be tested **monthly**
- Failed backups must be reported immediately

Data Retention

- Critical data retained for a minimum of **1 year**
- Old backups securely deleted when no longer required

Internet Usage Guidelines

Acceptable Use

- Internet access is primarily for official work purposes
- Limited personal use is allowed if it does not affect productivity
- Only authorized software may be downloaded

Prohibited Activities

- Accessing illegal or inappropriate websites
- Downloading pirated or unauthorized software
- Sharing confidential company information online
- Clicking suspicious links or attachments

Email Security

- Verify unknown email senders
- Do not open suspicious attachments
- Report phishing emails to IT immediately

Remote Access

- VPN must be used for remote connections
- Public Wi-Fi should not be used for sensitive tasks without VPN
- Company data must not be stored on personal devices without approval

Incident Reporting

- Any suspected security breach must be reported immediately to the system administrator.
- Examples include:
    - Lost or stolen devices
    - Suspicious login activity
    - Malware infections

Compliance

Failure to comply with this policy may result in:

- Disciplinary action
- Termination of employment
- Legal action if applicable.

This basic security policy ensures protection of organizational data, minimizes cyber risks, and promotes responsible technology usage within a small office environment.

5# Write a program to test password strength based on length, complexity, characters, and patterns. Use it to evaluate common passwords

```
def check_password(password):
    strength = 0
    feedback = []

    if len(password) >= 8:
        strength += 1
    else:
        feedback.append("Password is too short (min 8 characters).")

    has_upper = has_lower = has_digit = has_special = False
    special_chars = "!@#$%^&*"

    for char in password:
        if char.isupper():
            has_upper = True
        elif char.islower():
            has_lower = True
        elif char.isdigit():
            has_digit = True
        elif char in special_chars:
            has_special = True

    if has_upper:
        strength += 1
    else:
        feedback.append("Add at least one uppercase letter.")

    if has_lower:
        strength += 1
    else:
        feedback.append("Add at least one lowercase letter.")
```

```
    if has_digit:
        strength += 1
    else:
        feedback.append("Add at least one number.")

    if has_special:
        strength += 1
    else:
        feedback.append("Add at least one special character (!@#$%^&*).")

    if strength == 5:
        rating = "Very Strong"
    elif strength >= 3:
        rating = "Moderate"
    else:
        rating = "Weak"

    return rating, feedback

user_password = input("Enter a password to test: ")
rating, suggestions = check_password(user_password)

print("\nPassword Strength:", rating)
if suggestions:
    print("Suggestions:")
    for s in suggestions:
        print("-", s)
```

```
Enter a password to test: sAFura123@

Password Strength: Very Strong
```